

Technology Architecture / Technical Approach

Technical assessment

Evidence Locker uses a pragmatic layered web architecture: a React/Vite frontend, an Express/Node.js API, MongoDB persistence, dedicated evidence utilities, PDF generation, and an authenticated Gemini chatbot route.

Architecture judgment

The choices are appropriate for a pilot and small-to-medium production deployment. They support clear separation of concerns, rapid iteration, evidence handling, and future scaling, provided production operations add monitoring, backups, strict secrets management, and security testing.

Evaluation scope

- Architecture and component boundaries.
- Technology fit and maintainability.
- Evidence and data flows.
- Scalability, reliability, and deployment evolution.
- Security, privacy, and responsible AI controls.

1. System Architecture

The platform is organized into layers that keep presentation, business workflows, persistence, evidence processing, and external services understandable and independently maintainable.

Presentation layer

React, Vite, React Router, Tailwind CSS, authenticated pages, complaint forms, evidence views, and chatbot UI.

API and application layer

Express routes for auth, complaints, evidence, audit, jurisdiction, and chat with middleware for auth, roles, and errors.

Data layer

MongoDB/Mongoose models for users, complaints, evidence, auth sessions, OTP challenges, rate limits, and audit logs.

Evidence and document services

GridFS/storage utilities, Multer validation, metadata extraction, SHA-256 hashing, retention support, and pdf-lib package generation.

Architectural strengths

- The modular route and utility structure is easy to understand and extend.
- Authentication, authorization, validation, and error handling are represented as reusable middleware or service boundaries.
- Evidence processing is separated from complaint workflow logic, enabling future storage or extraction changes.
- The frontend can evolve independently from the backend through a clear API boundary.

2. Technology Choices

Technology	Assessment
React + Vite	Good fit for an interactive, component-based complaint workflow with fast development and static production builds.
Node.js + Express	Good fit for I/O-heavy APIs, uploads, authentication, and integration with email, Gemini, and MongoDB services.
MongoDB + Mongoose	Flexible document model matches variable fraud-specific form data and evidence metadata; requires indexes and operational controls at scale.
Multer + GridFS/storage	Appropriate for controlled uploads and large evidence objects; production needs durable storage, quotas, scanning, and lifecycle policy.
exifr + SHA-256	Useful combination for available metadata extraction and post-upload integrity verification, with clear limits around pre-upload originality.
pdf-lib	Practical for server-side generation of consistent complaint packages without requiring a separate document service.
Gemini API	Useful for bounded guidance and report assistance; requires privacy review, availability handling, cost controls, and human verification.

Technology-choice conclusion

The stack prioritizes developer availability, mature libraries, and a low operational barrier. No technology choice is inherently blocking; the main risks are production configuration, data governance, scaling discipline, and security operations.

3. Data, Evidence, and AI Flows

Complaint and evidence flow

- 1 Authenticate**
User signs in through OTP/JWT session flow and receives role-scoped access.
- 2 Create**
Complaint data is validated, sensitive contact fields are encrypted, and the record receives a lifecycle status.
- 3 Upload**
Files pass type, count, and size checks before evidence storage and metadata processing.
- 4 Record**
Metadata, SHA-256 hash, timestamps, source context, and custody events are linked to the complaint.
- 5 Review**
Authorized users view, update, forward, clarify, accept, reject, or prepare the complaint package.

AI chatbot flow

- The authenticated chat route accepts bounded conversation history and validates the final turn.
- When an authorized incident ID is supplied, only selected evidence metadata is loaded; the underlying files are not sent through this route.
- A bounded system instruction directs the model to avoid fabricated facts, secrets, definitive legal conclusions, and evidence authentication claims.
- Timeouts, transient retry handling, upstream error mapping, and missing-key responses prevent success-shaped failures.

4. Scalability and Reliability

The architecture is suitable for an initial pilot and can scale through managed infrastructure and targeted separation of resource-heavy workloads. Evidence files and AI requests are the most likely sources of cost, latency, and capacity pressure.

Scale path

- Use stateless API instances behind a load balancer; keep session state in the database or a shared session store.
- Add database indexes, query limits, pagination, connection-pool tuning, and archival strategies as complaint volume grows.
- Move evidence storage to durable object storage or a managed GridFS-compatible service with lifecycle and quota policies.
- Process metadata extraction, hashing, PDF generation, retention cleanup, and notifications asynchronously when workload justifies queues or workers.
- Add caching only for non-sensitive, well-defined data; do not cache private complaint or evidence responses without a clear invalidation policy.

Reliability requirements

- Automated health checks, structured logs, metrics, alerting, and request correlation IDs.
- Database backups, restore tests, evidence durability checks, and documented recovery objectives.
- Graceful handling of email, Gemini, storage, and database outages with actionable errors and retry policy.
- Load and performance tests covering uploads, concurrent users, package generation, and chat timeouts.

5. Security and Production Readiness

The implementation includes meaningful security foundations, but production security is a continuing operational practice rather than a one-time feature checklist.

Authentication and authorization	OTP login, JWT sessions, role-based access, ownership checks, and restricted route actions.
Data protection	Encrypted complaint contact fields, secure secret configuration, HTTPS requirement, and controlled evidence access.
Input and API protection	File type validation, upload limits, request validation, rate-limit support, CORS configuration, and security headers.
Integrity and accountability	SHA-256 hashes, custody logs, audit records, timestamps, status transitions, and handoff details.
AI safety	Authenticated access, bounded context, explicit system boundaries, no secret requests, timeout handling, and human verification.

Production hardening still required

Complete dependency and security scanning, penetration testing, privacy review, secret rotation, least-privilege database access, backup validation, abuse monitoring, retention enforcement, and incident-response exercises before broad deployment.

6. Overall Technical Evaluation

Evidence Locker has a coherent and appropriate technical approach for its intended problem. The architecture supports rapid development, clear ownership of responsibilities, evidence-specific processing, and future deployment evolution.

Architecture rating: **APPROPRIATE WITH HARDENING**

Technical feasibility is high for pilot use and credible for production after operational controls, scale testing, security review, and governance requirements are completed.

Priority technical actions

- Introduce automated tests for authorization boundaries, evidence ownership, metadata handling, PDF output, and chat safety/error paths.
- Define deployment topology, backups, observability, retention, recovery objectives, and operational runbooks.
- Perform security and privacy review of uploads, encrypted fields, logs, third-party AI requests, and administrator access.
- Plan asynchronous processing and durable evidence storage before usage or file volume makes synchronous workflows a bottleneck.
- Maintain human review for AI output and formal review for generated complaint packages and legal attestations.

Final conclusion

The selected technologies are maintainable, scalable in stages, and suitable for the Evidence Locker use case. With disciplined production hardening, the architecture can support a reliable, secure, and auditable complaint-support service.